

Incident Response

On suspected account compromise: revoke the user’s sessions (immediate refresh-token invalidation) and/or disable the user; for org-wide issues, suspend or revoke the pilot (global sign-out of all members). Access-token propagation bound is 300s (revalidation interval); refresh invalidation is immediate. Record every action as a nonfinancial security event. Because customer financial data never reaches Supabase, a control-plane incident does not expose financial files. For lost authenticator: dual-control MFA reset. Escalate production incidents per the (pending) production runbook.